14 Policy governance

This chapter covers

- How to govern policies across teams and systems
- The policy management lifecycle
- The roles, artifacts, and structures that make governance effective
- How Identity Governance and Administration (IGA) aligns with policy governance to ensure consistent access assurance
- Using governance to meet regulatory requirements and build organizational trust in authorization decisions

When ACME first deployed Cedar as its policy engine, the engineering team celebrated what seemed like the end of a long journey. Policies were versioned in Git, automatically tested, and deployed to production alongside code. The company's Customer Collaboration platform could finally make consistent, auditable authorization decisions across tenants and services. For a while, that was enough.

Then the problems started to multiply, not in the code itself but in the discussions surrounding it. Two product teams maintained nearly identical policies with subtle differences that no one could fully explain. The compliance team found that an old data-sharing policy was still active long after the retention period it referenced had expired. A new engineer, trying to resolve a support issue, discovered a temporary policy override that had been in place for nine months. Each incident uncovered the same core issue: ACME had mastered policy deployment but not policy governance.

The identity team recognized that policies, like identities, go through lifecycles. Each starts with a need—a new feature, regulation, or business process—but once established, they develop their own momentum. Without clear ownership, review schedules, and feedback mechanisms, policies amass technical debt just as software does. Even more concerning, since